

Two Factor Authentication Configuration User Guide

PeopleXD Security

Table of Contents

Document Control	3
1. Overview.....	4
1.1. Purpose of the Guide	4
1.2. Overview.....	4
1.3. Who should read this document.....	4
1.4. Assumptions and Constraints	4
2. How to Use	6
3. Administrator Configuration	8
3.1. Manage Two Factor Authentication	8
4. Employee Configuration	11
5. FAQ's	14

Document Control

Version	Date	Author	Details
1.0	July 2016	Darragh Duffy	Reviewed and release document
1.1	July 2016	Darragh Duffy	Updated questions section based on additional questions for Product Ops & Customers
1.2	April 2022	Stefan Brauer	Updated Images and branding removed reference to admin view of trusted numbers.
1.3	April 2023	Pat Conlon	Updated for Twilio based solution
1.4	May 2023	Kat Murie	Reformatted, condensed Section 2, published to knowledge base.
1.5	03/09/2025	Georga Edwards	Updated Note in Section 1.4 Assumptions and Constraints . Added additional Note in Section 1.4 Assumptions and Constraints for creating a new API.

1. Overview

1.1. Purpose of the Guide

The purpose of this document is to provide guidance on configuring two factor authentication (2fa) in PeopleXD. This includes:

- How to use 2fa
- How to configure as an administrator
- How to configure as an employee

1.2. Overview

Two factor authentication is an additional layer of security in the authentication process for PeopleXD Portal. This issues an SMS code to a user's registered mobile device.

1.3. Who should read this document

This document is intended for the following:

- Any member of XD projects, delivery and implementation team.
- XD customer support division.
- Customers making a decision to two factor authentication for PeopleXD.
- Independent Security Audit individuals.

1.4. Assumptions and Constraints

- The solution outlined here is for customer configured to use standard XD Employee Self Service (ESS) authentication. If you are using SSO via an IdP this setup is not applicable as 2FA/MFA would be managed via your IdP solution.

- To send the SMS messages you will need an active Twilio account* with the following details at hand to configure it withing PeopleXD.
 - Twilio Account SID
 - Twilio API Key
 - Twilio API Secret/Token
 - Twilio Phone Number (i.e. the sending number)

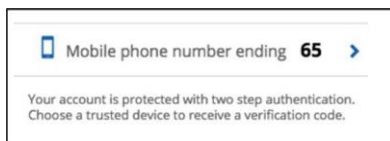
 **Note:** Access PeopleXD does not provide the Twilio account, this is the customer's responsibility. The account must be a fully paid Twilio account, 2fa CANNOT function with a free trial account.

 **Note:** As the default API key in Twilio is for account management and not SMS sending, please create a new API in the API & Tokens section on your Twilio dashboard (using the recommend region) Ensure that you copy the secret key information as it won't be displayed again.

2. How to Use

If 2fa is set up, when a user attempts to login with a valid username & password, they are presented with a list of certified mobile numbers. Once the user selects one of the listed numbers, an SMS message is issued to this mobile number. The user will be requested to enter this unique number and complete the sign in process. The following screenshots display the user workflow:

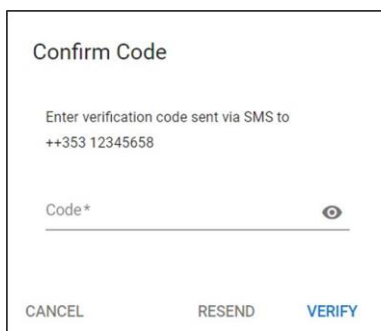
1. The user enters a valid username / password combination, then must select a mobile number:



It is possible for a user to have more than one certified mobile number, if this is the case, they can choose which one to issues the SMS to:



2. Once an SMS message has been issued, the user can enter the unique SMS code:



There is also a *Don't ask again on this computer* option, allowing the user to indicate this is a trusted browser, and do not ask again when the user logs in via this browser.

3. A user may click **Resend** to send a SMS message again; if the user requests a new SMS message, they are required to wait 60 seconds before issuing another SMS message to

the same number. The following message appears if the user attempts to issue additional SMS codes within a minute:

Please wait at least one minute for previous token to arrive.

The Security page in a user's account profile displays the method of authentication. In the following screenshot, the user has 2fa set up. This also indicates to which number an SMS was issued:

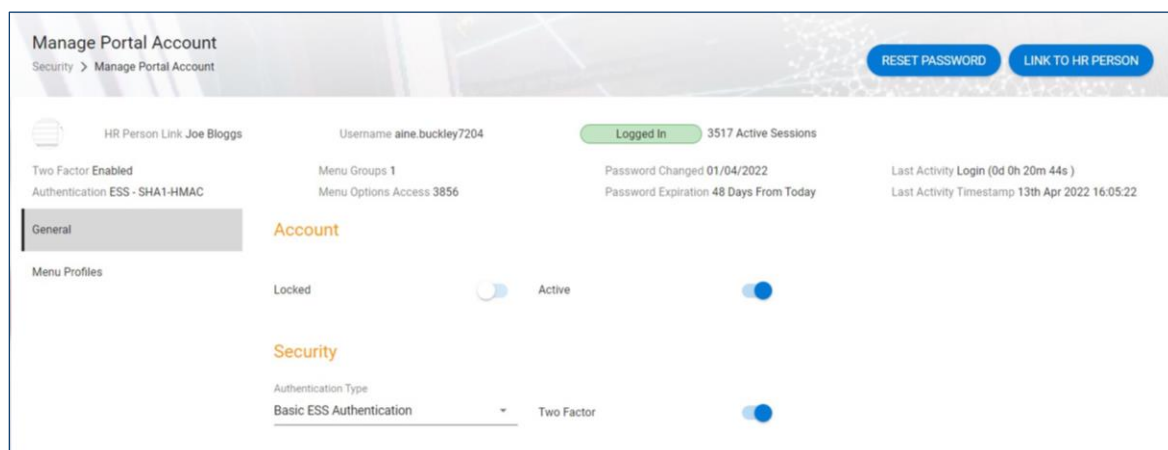
Recent Account Activity (last 90 days)

04th Jul 2016 13:18:05 **Login (two factor)** Chrome (Mac OS X, 10.11.5)

04th Jul 2016 13:17:24 **Two factor token issued to *****65** Chrome (Mac OS X, 10.11.5)

Administrators can view a user's two factor set up. To do this, follow the below steps:

1. Navigate to Security.
2. Click the **User Management** tab.
3. Search for the user in the System Users widget.
4. Click the 3-dot menu on the relevant user, then click **Manage Account**.
5. The screen allows you to disable/enable 2fa and shows the current status.



Note: If forced 2fa is enabled, disabling 2fa for an individual user will make no difference.

See section [3 Administrator Configuration](#) for more detail.

3. Administrator Configuration

For employees to use 2fa, an administrator needs to enable it for the organisation. This can be done in two ways:

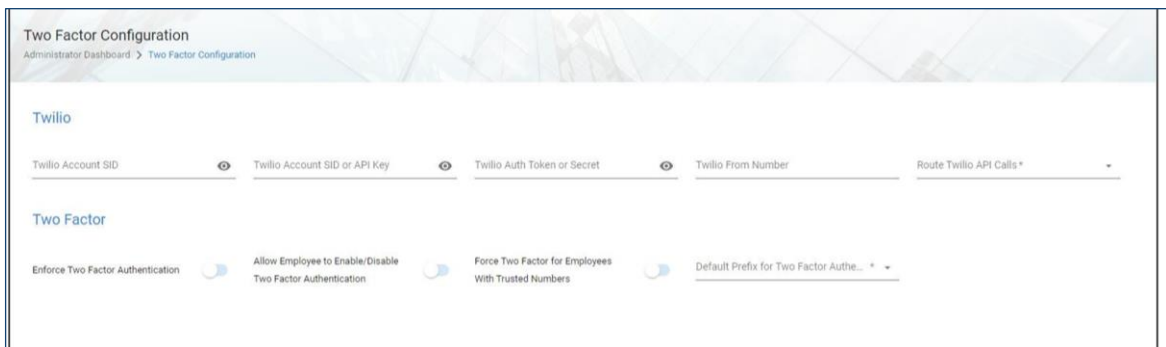
1. **Allow the employees to set up 2fa themselves.** The employee has the choice to enable/disable the 2fa in their account profile.
2. **Forced 2fa.** In this scenario, the employee cannot disable the authentication. When this option is set by the administrator, any mobile numbers associated with the employee are automatically set up as trusted numbers. The employee can add more, or delete some, but will not be allowed to delete the last remaining number. If an admin in HR adds or amends any contact numbers of the person, this change will also be reflected in the trusted numbers.

Note: In the scenario where Forced 2fa has been configured, and no mobile contact numbers exist for an employee, there will be no 2fa enabled for that employee.

3.1. Manage Two Factor Authentication

To manage two factor authentication configuration as an administrator, follow the below steps:

1. Navigate to the Administrator Dashboard
2. From the *Site Manager* widget, click **Open** on *Two Factor Configuration*



The screenshot shows the 'Two Factor Configuration' page in the Administrator Dashboard. The page has a header with the title 'Two Factor Configuration' and a breadcrumb 'Administrator Dashboard > Two Factor Configuration'. Below the header, there are two main sections: 'Twilio' and 'Two Factor'. The 'Twilio' section contains five input fields: 'Twilio Account SID', 'Twilio Account SID or API Key', 'Twilio Auth Token or Secret', 'Twilio From Number', and 'Route Twilio API Calls *'. The 'Two Factor' section contains four settings: 'Enforce Two Factor Authentication' (a toggle switch), 'Allow Employee to Enable/Disable Two Factor Authentication' (a toggle switch), 'Force Two Factor for Employees With Trusted Numbers' (a toggle switch), and 'Default Prefix for Two Factor Authentication' (a dropdown menu).

3. Amend the details as required.

4. Click **Save**.

 **Note:** To see the Two Factor Authentication option in the Site Manager widget, the following menu option is required: *CorePortal - Two Factor Configuration*.

We endeavour to enable all Webservice menu options in advance, however in the event of any access denied errors on the Two Factor configuration screen, please check that the following menu option is enabled: *WS_SYSTEM_MENU.GET_SECURITY_SETTINGS_TWOFACITOR*.

The two factor authentication screen contains the configuration attributes for both your Twilio account, and XD parameters to configure for how 2fa should work in your organisation.

 **Note:** You will need to have your Twilio account set up and have access to the details outlined in the table below in order to configure 2fa.

The following table outlines the items on screen:

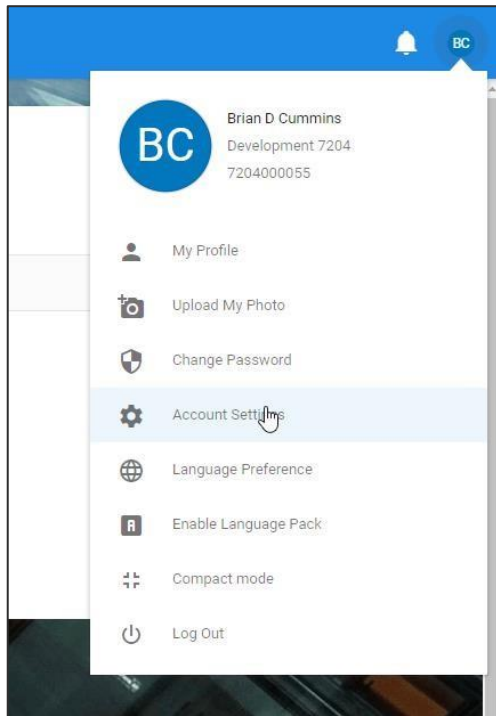
Item	Notes
Account SID	Available from your Twilio account
API Key	Available from your Twilio account
Token/Secret	Available from your Twilio account
From No.	Available/generated from your Twilio account
Enforce Two Factor Authentication	This parameter needs to be activated if you want to use two factor authentication for your organisation.
Allow Employees to enable/disable two factor authentication	If this parameter is active, individual employees can enable/disable the 2fa from their account settings.

Item	Notes
Force two factor authentication for Employees with trusted numbers	This enables 2fa for an employee using the mobile number in their HR contact information. The employee cannot disable this. Any employee who does not have a mobile number in their contact information will log in without 2fa. <u>If this parameter is enabled, it overrides the allow employee enable/disable2fa parameter.</u>
Default Prefix for two factor authentication	This sets the default code for when employees are adding trusted numbers (e.g. +44. +353 etc.)

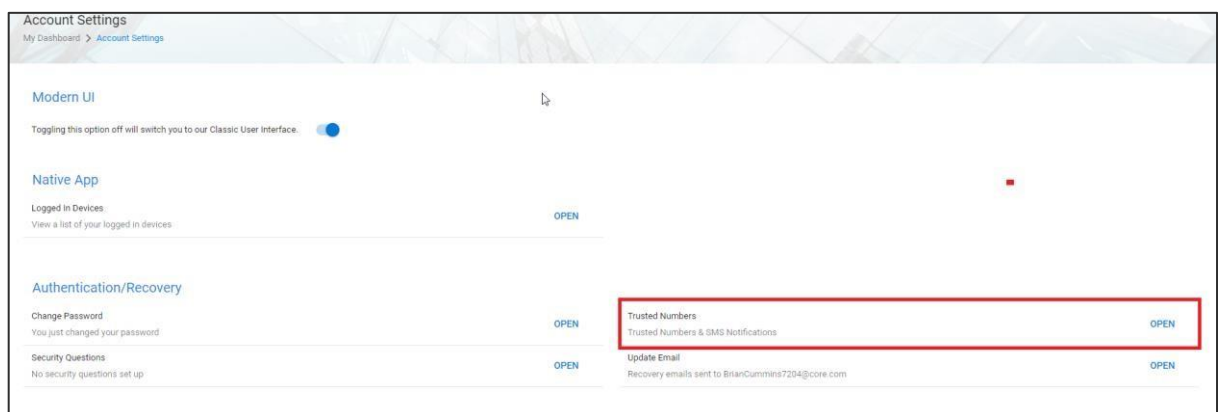
4. Employee Configuration

Employees can manage their trusted numbers and disable 2fa (if allowed to) from their account profile. To do this, follow the below steps.

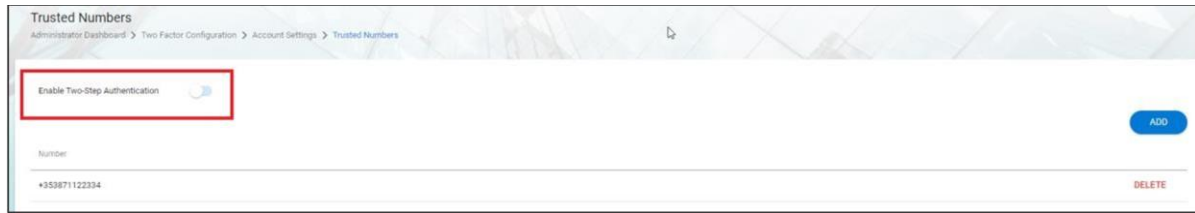
1. Click the account icon in the top right of the screen.
2. Click **Account Settings**.



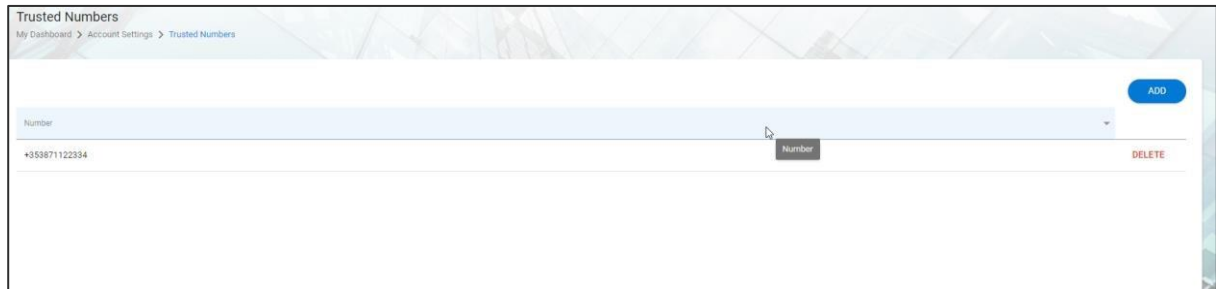
3. Click **Open** on Trusted Numbers.



The below screenshot displays an example of the screen if the configuration is set to allow employees to enable/disable 2fa and manage numbers:



Alternatively, the below screenshot displays an example of the screen where Forced 2fa is configured. Therefore, the employee can only manage their numbers:



Note: Where a user has enabled 2fa, they will always be required to have a least one mobile number set up. If a user attempts to delete the last mobile number where 2fa is still enabled, they will encounter an error.

To add a number, follow the steps below:

1. Click **Add**.
2. Enter the details for the additional mobile number. It isn't necessary to drop the first 0 in the mobile number. The screen validation caters for both standard mobile numbers, and international format.

Add Number

Enter a number capable of receiving text messages. A message will be sent with a verification code for the next step.

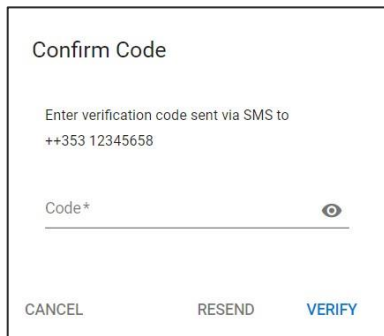
Country Code*
+353 (Ireland)

Number*

CANCEL OK

3. Click **OK**.

4. Then, a code is sent to the mobile number. Enter this in the *Code* field.



A screenshot of a 'Confirm Code' dialog box. The title 'Confirm Code' is at the top. Below it, the text 'Enter verification code sent via SMS to' is followed by the phone number '+353 12345658'. There is a text input field labeled 'Code*' with a small eye icon to its right. At the bottom, there are three buttons: 'CANCEL', 'RESEND', and 'VERIFY'.

5. Click **Verify**.

 **Note:** If you do not receive the SMS immediately, you need to wait 60 seconds before resending. Each code will be valid for 5 minutes.

5. FAQ's

To support you with Two Factor Authentication, we have collated the most common questions you've asked us:

Question	Answer												
Will Two Factor authentication work with SAML?	No, where SAML is used, the responsibility of authentication remains with the iDP.												
Will Two factor authentication work for TBA (Trust based Authentication)?	No, where TBA is used, the responsibility of authentication remains with the authority performing the authentication.												
What happens with incorrectly structured mobile numbers?	Every phone no. entered will be validated by sending an SMS code that has to be inputted before the trusted number will be added to the system. All of the following examples result in the mobile number 353878384365 being used to issue the SMS code. These are examples of a differences in setting up mobile number in the Contacts section with the contact type 'MOB'. The system caters for such variation and can extract the number: <table> <tbody> <tr> <td>+0878384365</td><td>+353878384365</td></tr> <tr> <td>00878384365</td><td>0878384365</td></tr> <tr> <td>878384365</td><td>3530878384375</td></tr> <tr> <td>+3530878384365</td><td>(087)8384365</td></tr> <tr> <td>087-8384365</td><td>087 8384365</td></tr> <tr> <td>087 -- 8384365</td><td>+ 87 8384365</td></tr> </tbody> </table>	+0878384365	+353878384365	00878384365	0878384365	878384365	3530878384375	+3530878384365	(087)8384365	087-8384365	087 8384365	087 -- 8384365	+ 87 8384365
+0878384365	+353878384365												
00878384365	0878384365												
878384365	3530878384375												
+3530878384365	(087)8384365												
087-8384365	087 8384365												
087 -- 8384365	+ 87 8384365												
Where are the individuals' mobile numbers obtained?	Mobile numbers are obtained in two ways: 1. In People Management, contact details are picked up based on the contact type <i>MOB</i> or <i>Mobile</i>												

Question	Answer
	2. Users can add new mobile numbers. These are called certified numbers; a user can add these via account security page.
An error appears indicating wait at least one minute for token to arrive. What is this and can this be changed?	A user can only issue an SMS once per minute. This cannot be changed.
What is the default contact type in PeopleXD contacts?	<i>MOB</i> (Mobile number) and <i>Mobile</i> (Work Mobile Number)
Can an individual set up more than one mobile number?	Yes. See Section 4 Employee Configuration for more detail.
How long does the token take to issue to the individual?	Typically, an SMS will issue within 5 seconds of the request. We have performed a bulk test with 10,000 SMS messages; all messages were received within 5 seconds.
Is it possible for an individual to delete all mobile numbers and lock themselves out of application?	No, this is not possible, a user cannot delete the last remaining number.
How does an administrator add mobile numbers for a user?	The only method for an administrator to set up mobile numbers is through XD contact set up. In People Management, adding a Mobile Number (<i>MOB</i>) or a Work Mobile Number (<i>Mobile</i>).